

ضوابط الأمن السيبراني الأساسية (ECC-1:2018)

الصفحة 1 من 3 | كود المستند: doc_ar_02

المجال الأول: حوكمة الأمن السيبراني واستراتيجية الدفاع

يجب على كافة الجهات إعداد وتوثيق استراتيجية معتمدة للأمن السيبراني متوافقة مع الأهداف المؤسسية.

يتعين مراجعة سياسات وإجراءات الأمن السيبراني دوريا واعتمادها من قبل صاحب الصلاحية مرة واحدة على الأقل سنويا.

المجال الثاني: إدارة الهوية والتحكم في الوصول الرقمي

يجب تطبيق متطلبات المصادقة متعددة العوامل (MFA) لجميع عمليات الوصول عن بعد وحسابات المسؤولين المميزين.

يجب ألا يقل الحد الأدنى لطول كلمات المرور عن 12 خانة مع إلزامية تعقيد الرموز وتغييرها كل 90 يوما.

المجال الثالث: حماية الأنظمة والشبكات ومقاومة التهديدات

يجب عزل الشبكات الحساسة وأنظمة التحكم الصناعي عن شبكات المكاتب العامة باستخدام جدران نارية متقدمة.

يلزم إجراء فحص دوري للثغرات الأمنية للأنظمة والشبكات كل ثلاثة أشهر (ربع سنوي) على الأقل ومعالجة النتائج.

المجال الرابع: اختبارات الاختراق السنوية

يجب إجراء اختبار اختراق سيبراني مستقل سنويا لكافة الخدمات والتطبيقات الخارجية المتاحة عبر شبكة الإنترنت.

يتعين توثيق تقرير نتائج اختبار الاختراق ومعالجة الثغرات عالية الخطورة خلال 15 يوما من تاريخ صدور التقرير.

المجال الخامس: خطط التعافي والنسخ الاحتياطي المعزول

يجب الاحتفاظ بنسخ احتياطية دورية ومعزولة ماديا أو منطقيا (Air-gapped) عن الشبكة التشغيلية الرئيسية لمنع هجمات الفدية.

يتعين اختبار استعادة النسخ الاحتياطية وإجراءات التعافي من الكوارث مرتين على الأقل كل عام للتأكد من جاهزيتها.

يجب توفير بيئة عمل بديلة للأنظمة الحرجة قادرة على استئناف العمليات خلال ساعتين من وقوع انقطاع كارثي.